SOFTWARE CHANGE IMPLEMENTATION REPORT

CR-026: Forgotten Password and Password Reset Feature

Field	Details
Change Request ID	CR-026
Change Request Title	Forgotten Password and Password Reset Feature
Student Name	N. Bavanika
Student ID	JFICT24_19
Implementation Status	Completed
Date	14 October 2026

1. Change Request Summary

1.1 Business Requirement

The Student Management System should help students reset a forgotten password. A student enters the email address saved on their account, receives a one-time password (OTP), and uses it to set a new password.

The main goals are:

- Add a Forgot Password link to the login form.
- Find the student account using its registered email address.
- Send a one-time code by email. The code must expire after a set time.
- Check the code before allowing a new password.
- Save the new password securely and prevent the code from being used again.
- Keep normal login, administrator access, and student management working.

1.2 Existing Behaviour

- The login page did not have a Forgot Password link.
- Students could not use an email code to reset a forgotten password.
- A safe password reset process was needed for each student account.

1.3 Requested Change

Add a Forgot Password process. The student enters their registered email, receives a one-time code, verifies the code, and enters and confirms a new password.

2. Implementation

2.1 Implementation Summary

CR-026 was added to the login page, password recovery pages, login API, user model, and database setup. The login form now has a Forgot Password link. Students enter the email saved on their account and receive a code through the configured email service. They then enter the code and a new password.

The system creates a random code and saves only its secure hash, expiry time, and attempt count. It replaces older active codes and sends the new code by email. After a valid code is checked, the system securely hashes the new password and updates the correct account. Email service passwords and keys are kept in backend settings and are not included in this report.

2.2 Affected Files

File / Component	Change	Purpose
frontend/src/components/LoginFormSection.jsx	Modified	Add the Forgot Password link to the login form.
frontend/src/pages/ForgotPasswordPage.jsx	Modified	Ask for the registered email and request a code.
frontend/src/pages/ResetPasswordPage.jsx	Modified	Ask for the code and new password, then submit the reset.
frontend/src/services/authService.js	Modified	Send password reset requests to the backend.
frontend/src/styles/login.css	Modified	Style the recovery link and reset forms.
backend/src/routes/authRoutes.js	Modified	Add the password reset API routes.
backend/src/controllers/authController.js	Modified	Create and email codes, check reset requests, and update passwords.
backend/src/models/userModel.js	Modified	Find accounts by email and manage reset codes and passwords.
backend/src/controllers/studentController.js	Modified	Keep the student email in line with the account email.
database/schema.sql	Modified	Set up account email and reset code storage.
database/migrations/CR026_password_reset_setup.sql	Added	Add account email support and the reset code table.
database/migrations/CR026_password_reset_otp_attempts.sql	Added	Track code verification attempts.

2.3 Technical Changes

The student opens Forgot Password, enters their registered email, and requests a code. The reset page then asks for the code, a new password, and password confirmation.

The backend sends email using the configured SMTP settings. It uses Node.js tools to create a random code, SHA-256 to protect the stored code, MySQL to save the reset details, and bcryptjs to protect the new password. Email service secrets are stored in backend settings.

The database changes add the account email and a table for password reset codes. The table stores a protected code, expiry time, usage status, and number of attempts. Each code is linked to the correct account and cannot be used again after a successful reset.

2.4 Implementation Logic

- The student opens Forgot Password from the login form.
- The student enters the email address saved on their profile.
- The system finds the account and creates a code that expires after a set time.
- The code is sent by email. Only its protected hash is saved in the database.
- The student enters the code, a new password, and password confirmation.
- The system checks that the code is correct, has not expired or been used, and is within the attempt limit.
- If the code is valid, the system securely saves the new password for that account.
- The system marks the code as used and shows the result.

2.5 Error and Data Handling

- Reject missing or invalid email, code, and password details.
- Reject wrong, expired, used, or over-limit codes.
- Set a time limit and an attempt limit for code checks.
- Use a general response so the page does not reveal whether an account exists.
- Show extra error details only in development when configured. Keep public responses general.
- Never save passwords or codes as plain text, and never log secrets or email service passwords.
- Update only the account linked to the verified reset request.
- Keep normal login and administrator access working as before.

3. Testing & Verification

3.1 Testing Approach

All 15 test cases are marked as passed in this report.

Test environment and browser details were not included in the source report.

The test cases below cover the CR-026 password reset requirements.

3.2 Test Cases

Test ID	Test Case	Expected Result	Actual Result	Status
TC-01	Open Forgot Password from login	Recovery page opens.	Forgot Password page opened successfully.	Pass
TC-02	Submit a valid registered email	OTP request accepted and email sent.	OTP request was successful, and the email was sent.	Pass
TC-03	Submit malformed email	Input rejected with validation feedback.	Invalid email was rejected with an error message.	Pass
TC-04	Submit unknown email	Generic response avoids account disclosure.	A general response was displayed without revealing account details.	Pass

TC-05	Enter an incorrect OTP	Reset is rejected.	The system rejected the incorrect OTP.	Pass
TC-06	Enter an expired OTP	Reset is rejected.	The system rejected the expired OTP.	Pass
TC-07	Reuse a consumed OTP	Reset is rejected.	The system rejected the OTP that had already been used.	Pass
TC-08	Exceed allowed OTP attempts	Further verification is rejected.	The system blocked further attempts after reaching the OTP attempt limit.	Pass
TC-09	Submit mismatched password confirmation	Reset is rejected with validation feedback.	The system rejected passwords that did not match.	Pass
TC-10	Submit a weak password	Existing password policy is enforced.	The system rejected the weak password.	Pass
TC-11	Submit valid OTP and password	Password is hashed and updated for matching account.	The new password was saved securely for the correct account.	Pass
TC-12	Log in with the new password	New password is accepted.	Login was successful with the new password.	Pass
TC-13	Log in with the old password	Old password is rejected after reset.	Login was rejected when using the old password.	Pass
TC-14	Inspect reset data	OTP is hashed, expires, and is marked used.	The OTP was stored securely, expired after the set time, and was marked as used.	Pass
TC-15	Check existing login and management flows	Existing functions continue to work.	Existing login and student management functions worked correctly.	Pass

3.3 Test Summary

Test Result	Count
Total test cases	15
Passed	15
Failed	0
Pending	0
Pass rate	100%

4. Acceptance Criteria Verification

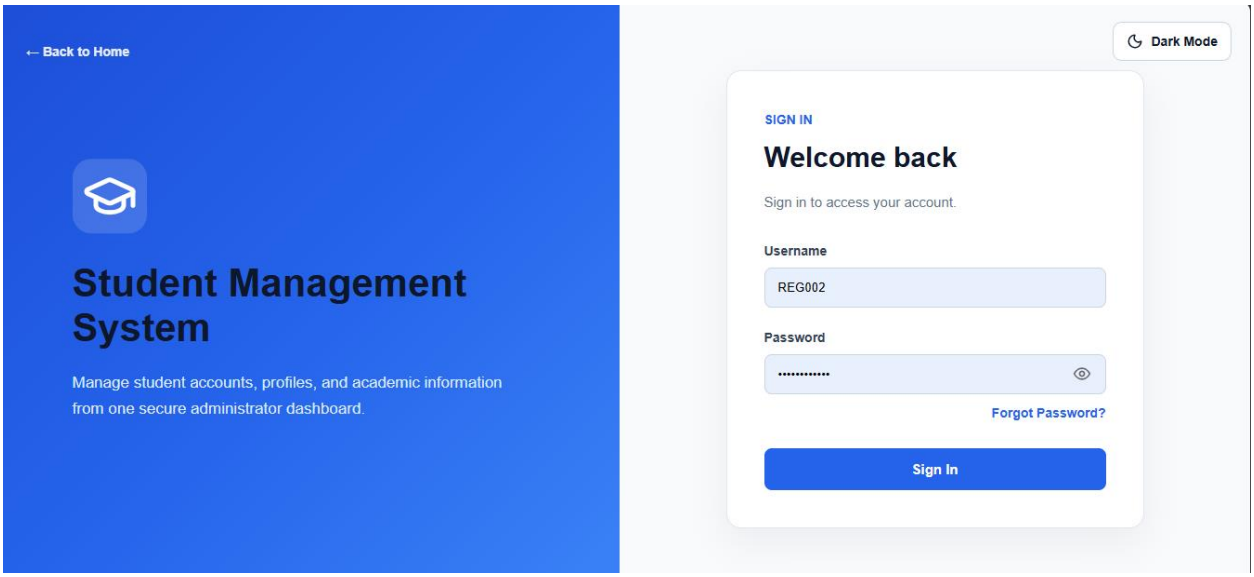
The acceptance criteria below match the CR-026 requirements. All items are marked completed in this report.

ID	Acceptance Criterion	Verification Evidence	Status
AC-001	Forgot Password is reachable from login.	Login component and recovery route.	Completed
AC-002	OTP is sent to registered student email by SMTP.	Auth controller and SMTP mail transport.	Completed
AC-003	OTP is time-limited and protected from repeated guessing.	OTP expiry and attempt tracking.	Completed
AC-004	Invalid, expired, or reused OTPs are rejected.	OTP verification and used-state handling.	Completed
AC-005	New password is validated and securely hashed.	Controller validation and bcryptjs.	Completed
AC-006	Successful reset updates intended account only.	Verified reset and user model update.	Completed
AC-007	Public response avoids account enumeration.	Generic recovery response behavior.	Completed
AC-008	Existing login and management behavior is preserved.	Regression scenarios in test cases.	Completed

5. Evidence

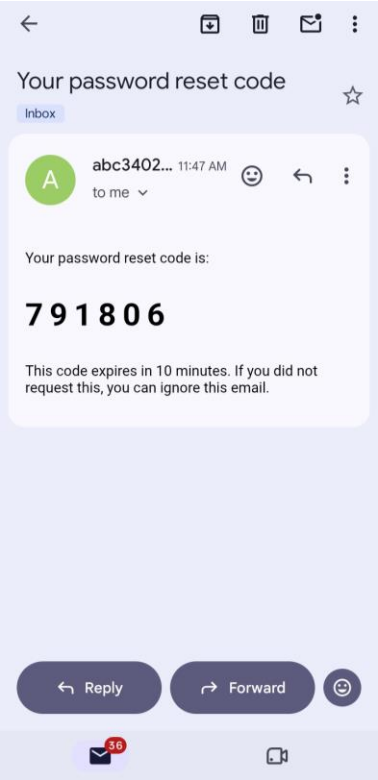
Evidence 01 - Forgot Password Link

Code reference: frontend/src/components/LoginFormSection.jsx.



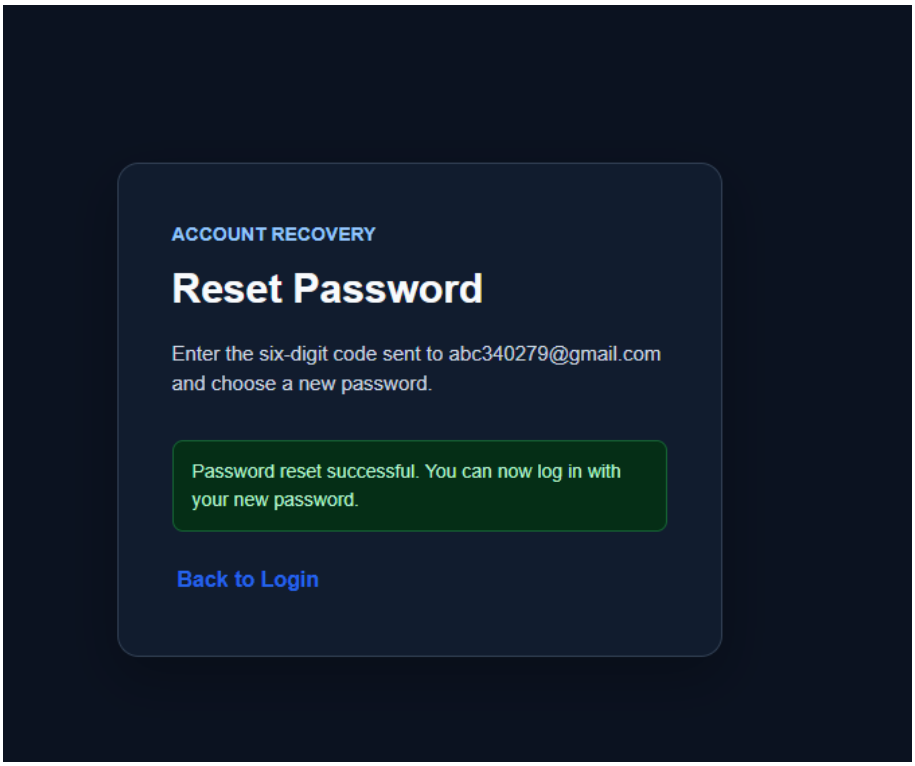
Evidence 02 - Email Code Request

Code references: frontend/src/pages/ForgotPasswordPage.jsx and backend/src/controllers/authController.js.

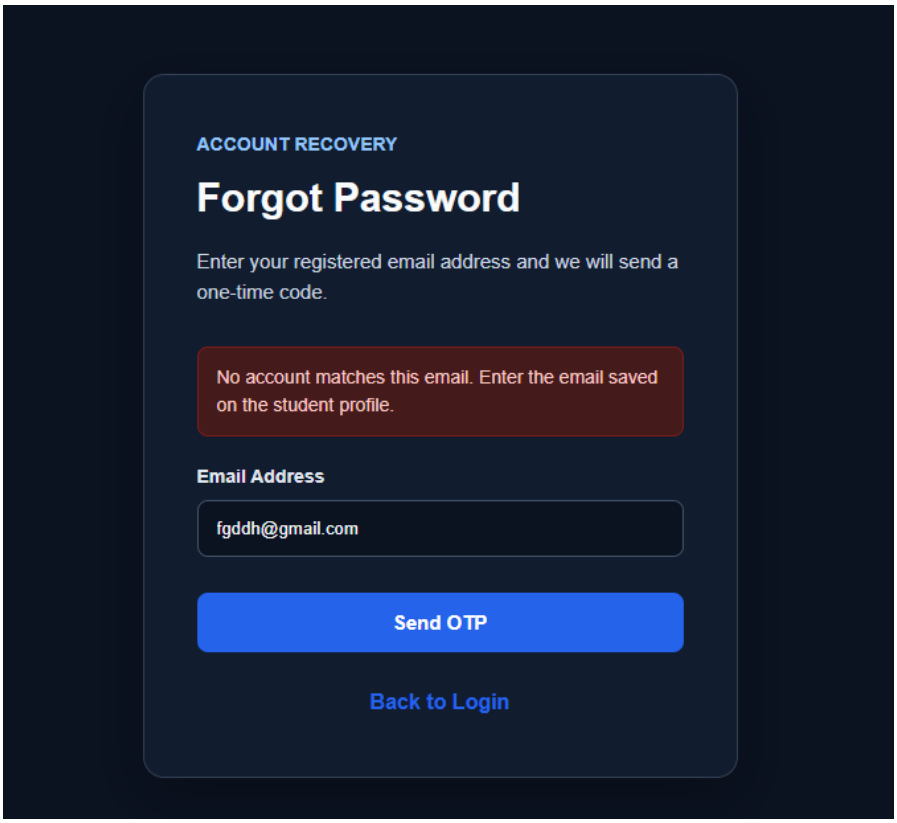


Evidence 03 - Code Check and Password Reset

Code references: frontend/src/pages/ResetPasswordPage.jsx, backend/src/models/userModel.js, and the CR026 database migrations.



Evidence 04 – Check Validation for not registered



6. Final Result

Item	Result
CR-026 password reset feature	Completed
Forgot Password link on login page	Completed
Email code delivery	Completed
Code expiry, protection, and attempt limit	Completed
Code checking and one-time use	Completed
Secure new password storage	Completed
Database setup and migration files	Completed
Testing	15 passed, 0 failed
Acceptance criteria	All completed and passed
Final status	Completed

6.1 Final Summary

CR-026 adds a password reset process for student accounts. A student enters the email saved on their profile and receives a code that expires after a set time. After the code is checked, the student can set a new password. The system protects the stored code and new password, limits code attempts, and prevents the code from being used again.

The login page, recovery pages, backend API, user model, database setup, and migration files have been updated. Email settings are kept in the backend environment. This report lists the implementation and test results.

6.2 Issues / Limitations

- Email delivery depends on correct email settings and the email provider being available.
- Apply the CR026 database changes before using the password reset feature.
- The test cases and acceptance criteria are marked as passed and completed in this report.
- Screenshots and test logs were not included in the source report.
- Keep the public password recovery response general so it does not reveal account details.

Student Name: N. Bavanika

Student ID: JFICT24_19

Date: 14 October 2026

Signature:

~ END OF REPORT ~